

THE FORENSICS WAY

ISSUE 34

FORENSICS AWARENESS THIS WEEK

TUESDAY, SEPTEMBER 22, 2026

FRONT PAGE

AI-ENABLED ATTACKS

Four AI Models, One Vote: Cisco Talos Uncovers Windows Malware That Lets an LLM Panel Decide What to Steal Next

Cisco Talos disclosed CLOSEDQUORUM on September 22, describing it as the first publicly documented Windows implant to delegate tactical command-and-control decisions to a panel of commercial large language models. On each run, the malware queries up to four AI services — DeepSeek, Qwen, Mistral, and Google Gemini, reached through OpenRouter — with the infected machine's computer name, Windows version, and admin status, then asks each model to pick one of four actions: steal, inject, persist, or move. Each model must answer in a fixed format or its vote is discarded; the action with the most votes wins, and if no model returns a usable answer the malware simply retries rather than falling back to a default. Talos found the sample using CAIRN, a new open-source toolkit it released the same day for hunting AI-integrated malware by scanning metadata — prompt templates, provider API endpoints, jailbreak terms — without ever executing the binary.

The "steal" action dumps LSASS memory for Windows credentials and pulls saved passwords from Chrome, Edge, and Firefox alongside MetaMask, Exodus, and other crypto wallet data; "inject" runs code in other processes via Early Bird APC injection or process hollowing; "persist" installs three separate mechanisms — a Registry Run key, a scheduled task, and a WMI event subscription that re-checks every 60 seconds. Stolen data is encrypted, chunked into 1,900-byte pieces, and exfiltrated through Discord webhooks. Forensic priority: hunt a Registry Run value named "WindowsUpdate," a PowerShell script at C:\Windows\Temp\wmi.ps1, and WMI event subscriptions using Windows Update-themed names; capture memory before remediation to recover the model responses that drove the malware's decisions, since that log is itself an evidentiary record of attacker intent.

NATION-STATE

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-5430

WSO2 API Manager — improper cryptographic-signature verification lets a JWT signed with an unsupported algorithm bypass authentication entirely; CVSS 9.8. watchTower's honeypots captured forged tokens carrying baked-in administrator privileges beginning September 13. Affects API Manager 4.1.0–4.6.0, API Control Plane, Traffic Manager, and Universal Gateway 4.5.0–4.6.0. *Forensic Note:* Review JWT validation logs for tokens signed with unexpected or unsupported algorithms, audit all administrator accounts created or modified since September 13, and patch immediately — this is an aggregation point for internal service credentials.

ACTIVE EXPLOIT

CVE-2026-51990

Tencent Sogou Input Method — a one-click RCE chaining unvalidated command-line argument injection in the sgbiz: URI handler, unrestricted navigation in a CEF-based webview, and an outdated, unsandboxed Chromium 80 engine. China-aligned actor UNC3569 is exploiting it to deploy the GrayRabbit backdoor (see Malware Spotlight). Patched in version 16.3.0.3498. *Forensic Note:* Confirm Sogou IME is updated past 16.3.0.3498 on every Windows host, audit browser and URI-handler history for sgbiz: invocations, and treat any host still on the vulnerable Chromium 80 component as unpatched regardless of reported version string.

The Friend Request That Wasn't: Iran's CHOSEN BRICK Spyware Impersonates Trusted Contacts to Surveil Dissidents and Journalists

The UK's NCSC, the FBI, and the Netherlands' AIVD issued a joint advisory this week exposing CHOSEN BRICK, a Windows spyware family Iranian state actors have used since at least 2025 against dissidents, activists, and journalists in the UK, US, and Netherlands. The attack begins with social engineering over WhatsApp or Telegram, with operators impersonating trusted contacts or technical-support agents to deliver malicious files disguised as legitimate software — fake Norton Antivirus, Adobe Flash Player, and KeePass installers among them. Once installed, CHOSEN BRICK leverages Telegram's own infrastructure to exfiltrate messages, contacts, files, screenshots, and microphone audio, giving operators a running picture of a target's associates and movements.

Personal information belonging to some victims has since surfaced on pro-Iranian leak sites, a step beyond surveillance into potential harassment and physical risk for people already identified as threats to the regime. Forensic priority: treat any unsolicited "trusted contact" file-share over WhatsApp or Telegram as a live intrusion attempt regardless of sender familiarity, verify installer authenticity against vendor-signed hashes before running anything received through a messaging app, and for suspected victims, prioritize Telegram session and device-authorization review — the malware rides the platform's own trust model rather than a separate C2 channel.

MALWARE SPOTLIGHT

GrayRabbit — The Backdoor Riding a Chinese Input Method's Chromium Flaw

GrayRabbit is a modular backdoor linked to UNC3569, a China-based actor spanning both cybercrime and contractor-for-hire espionage, dropped via the Sogou Input Method one-click exploit chain above. Once resident, it opens a reverse shell and can execute processes, load additional plugins, write data directly to the interactive shell, upload files to its C2, collect system information, and terminate itself on command — a compact but complete remote-access toolkit riding in through a keyboard utility hundreds of millions of Windows users have installed. *Forensic Note:* Hunt for reverse-shell network connections originating from IME-related processes, review plugin-load activity for the backdoor's modular components, and treat any Sogou-related process spawning a shell as compromise, not a false positive.

— PAGE 1 —

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, SEPTEMBER 22, 2026

CASE STUDIES: HISTORICAL GRID

REGIN (2014)

The Platform That Loaded Only What It Needed: A Six-Stage Espionage Framework Built for Any Target

THE PEGASUS PROJECT (2021)

Zero Clicks, Total Access: How Commercial Spyware Sold to Governments Became a Tool Against Journalists Worldwide

Discovered by Symantec in November 2014 after years of quiet operation against telecoms, governments, and research institutions, Regin was a modular espionage platform deployed across six discrete stages, each conditionally loaded depending on what the specific target environment required — a bespoke capability set assembled on the fly rather than a fixed toolkit. Its architecture treated "what to do next" as a decision to be made per-target rather than hardcoded in advance, requiring investigators to reconstruct the full stage chain across memory and disk before understanding what any single infection was actually capable of. This week's CLOSEDQUORUM pushes that same idea one step further: instead of a human operator's pre-built decision tree, an outside panel of AI models chooses the next stage in real time.

In July 2021, a consortium of journalists and Amnesty International's Security Lab revealed that NSO Group's Pegasus spyware — sold exclusively to government clients — had been used against journalists, human-rights defenders, and political dissidents across dozens of countries, often via zero-click exploits requiring no victim interaction at all. Forensic analysis relied on Mobile Verification Toolkit examination of device backups to find traces the spyware left despite its design to leave almost none, establishing device-forensics methodology that human-rights investigators still use today. CHOSEN BRICK is the same threat model at a lower budget: a state actor targeting the same class of victim, trading Pegasus's zero-click exploits for patient social engineering over apps its targets already trust.

CONFICKER (2008)

The Worm That Out-Coordinated Its Hunters: 15 Million Machines and an Algorithm Nobody Could Outrun

First detected in November 2008, Conficker exploited a single Windows Server Service vulnerability (MS08-067) to infect an estimated 9 to 15 million machines across 190 countries, but its lasting notoriety came from its update mechanism: a domain-generation algorithm producing thousands of possible rendezvous domains daily, so registering or blocking any one of them accomplished nothing. Defeating it required the unprecedented Conficker Working Group — security vendors, registrars, and governments coordinating in real time to pre-register generated domains faster than the worm's operators could reach them.

THE DARK AVENGER'S MUTATION ENGINE (1992)

The Toolkit That Taught Viruses to Never Look the Same Twice: Polymorphism's First Weapon-Grade Release

In 1992, the Bulgarian virus writer known as Dark Avenger released the Mutation Engine, a plug-in toolkit any virus author could attach to their malware so each new infection encrypted itself with different, randomly generated code — defeating the simple signature matching that antivirus software relied on entirely. It forced the antivirus industry to invent heuristic and behavioral detection almost overnight, since no static signature could keep pace with software that rewrote its own fingerprint on every run.

TOOLS OF THE TRADE

OPEN SOURCE

CAIRN

CISCO TALOS — V1.0 (MIT)

OPEN SOURCE

jwt_tool

TICARPI — V2.X

COMMERCIAL

Oxygen Forensic Detective

OXYGEN FORENSICS — V18.X

UTILITY / SCRIPT

PowerForensics

POWERFORENSICS — V2.X

Released the same day as this week's CLOSEDQUORUM disclosure, CAIRN hunts AI-integrated malware by scanning metadata — prompt templates, provider API endpoints, LangChain/LiteLLM library references, jailbreak terms — without executing the binary. Run it against your own sample repository to catch the next LLM-voting implant before Talos does.	JWT security-testing toolkit for probing signature validation, algorithm confusion, and claim tampering. Use it defensively to reproduce the CVE-2026-5430 unsupported-algorithm bypass against a staging WSO2 instance and confirm the patch actually rejects the forged token class watchTower captured.	Mobile and cloud forensic platform with deep Telegram extraction support, including deleted messages and session/device-authorization history. The primary tool for reconstructing what a CHOSEN BRICK victim's Telegram account actually exposed once the spyware rode the platform's own trust model.	PowerShell-native forensic framework for live Windows triage — Registry, file system, and WMI repository parsing without external dependencies. Purpose-built for hunting CLOSEDQUORUM's WMI event subscription persistence and its "WindowsUpdate" Run-key artifact directly from an incident responder's existing PowerShell session.
--	--	---	---

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-19490 (CITRIX NETSCALER ADC/GATEWAY)

Authentication-bypass flaw (CVSS 9.3) reaches an alternate authentication path with no credentials required. Exploited within days of a public PoC. CISA KEV. *Forensic Note:* Patch to 14.1-73.32/13.1-63.21 or later and review AAA/Gateway logs for bypassed login flows.

ARCHIVE ALERT

CVE-2025-25249 (FORTINET FORTIOS/CAPWAP)

Unauthenticated heap-based buffer overflow in CAPWAP packet processing; up to 30,000 targeted IPs and 178 confirmed victim sessions. CISA KEV. *Forensic Note:* Patch all affected FortiOS branches and hunt the PivotC2 RAT as the confirmed follow-on payload.

RECENT MALWARE WATCH

ARCHIVE: SEPTEMBER 15, 2026

PIVOTC2 — THE RAT RIDING FORTIGATE'S BUFFER OVERFLOW

Confirmed post-exploitation payload for CVE-2025-25249, giving attackers a pivot point directly inside compromised FortiGate appliances. Hunt unexpected outbound connections originating from the appliance itself rather than protected hosts.

ARCHIVE: SEPTEMBER 8, 2026

MANIC — THE ANDROID TROJAN THAT STEALS YOUR PIN WHILE THE APP WORKS FINE

Uses an invisible Accessibility overlay on the numeric keypad to capture PINs while passing taps through to the real app, then relays stolen data over Bluetooth or Wi-Fi to nearby infected devices when offline. Hunt unwarranted Accessibility service grants.